

INDICE

INDICE

Questo è uno dei più big **PopiPopi** della storia.
Gli argomenti con accanto un * sono roba in più che ho cercato e messo.

LE [Reti Cablate](#) (NON METTO LE LAN MA SOLO LE WAN)

- Definizione
- Tipi di Cavi
- Fibra Ottica
- [WAN](#)

I [Firewall](#)

- Definizione
- Policy
- Tipi di Firewall
- Firewall Software e Hardware

[Internet Security](#)

- Definizione
- Information Hiding
- [Crittografia](#) (DES, AES, DH, RCA, ECC e HASH)
- [Steganografia e Watermarking](#)

[Reti Wireless](#)

- Definizione
- Come funzionano
- Standard Principali
- Vantaggi e Svantaggi
- [Tipologia reti Wireless](#)
- [Attacchi alle Reti Wireless](#)
- [Sicurezza reti Wireless](#) (WEP, WPA, WPA2, WPA3 e RADIUS)

LE [VLAN](#)

- Definizione
- Vantaggi
- VLAN ID e Assegnazione
- Collegamenti
- VTP
- Inter-VLAN
- Private VLAN *

LE [VPN](#)

- Definizione
- Tipi di architetture
- IPsec

- Gateway VPN
- Tunneling
- Instradamento nella rete
- [SD-WAN](#) *

[Allocazione Risorse Server](#)

- DMZ
- [Configurazione di una DMZ](#) *
- Housing
- Hosting
- Cloud Computing

[RFID](#)

- Definizione
- Frequenze Usate
- Livelli Implementati
- NFC

[HTTP](#)

- Definizione
- Struttura dei messaggi
- Metodi
- Codici di Stato
- Cookie, Sessioni e Cache
- HTTPS

[FTP](#)

- Definizione
- Come Funziona
- Client FTP
- FTPS
- SFTP *

[SSH](#)

- Definizione
- Sicurezza e Autenticazione
- Funzioni Principali
- Architettura
- Handshake

[Appunti per la Prova Scritta](#) (Personalì 🦅)

DA FARE:

Virtualizzazione

SMTP/IMAP, VoIP, DNS, DHCP, MQTT, RTSP

Proxy???

NAT - PAT (Un accenno è sempre giusto metterlo)

Reti Cablate

Reti Cablate

Faccio solo un'infarinatura utile per la prova scritta

Definizione

Le reti cablate sono reti che usufruiscono di cavi per far passare la connessione. Sono più affidabili e sicure delle reti wireless. Oltre ciò hanno una velocità superiore e una bassa latenza.

Si usa lo standard IEEE 802.3 (Ethernet).

Tipi di Cavi

Categoria	Velocità Max	Frequenza
Cat 5e	1 Gbps	100MHz
Cat 6	1 - 10 Gbps	250MHz
Cat 6a	10 Gbps	500MHz
Cat 7/8	25/40 Gbps	2500MHz

Cat 5 solitamente è per le reti domestiche base mentre cat 7/8 viene usato in grandi datacenter.

Inoltre, con la tecnologia PoE (Power Over Ethernet), sui cavi viaggia anche energia elettrica.

Fibra Ottica

La fibra ottica è un'ottima soluzione per cablaggi a lunghe distanze. Essa usa impulsi luminosi invece che elettrici e ha 0 attenuazione alle onde elettromagnetiche e una velocità potenzialmente infinita.

FTTH (Fiber to the Home)

FTTH è il cablaggio che porta la fibra direttamente nelle case eliminando il vecchio doppino in rame.

WAN

WAN

Definizione

Una WAN (Wide Area Network) è una rete che copre una vasta area geografica usando infrastrutture di terzi (es. ISP).

Collegamenti

I vari nodi di una WAN si possono collegare in vari modi:

Linee Dedicate (Leased Line)

Un provider (ISP) garantisce un collegamento fisico o logico diretto e riservato tra due sedi. Sono molto sicure e hanno latenza minima, ma hanno costi molto elevati (usati solo per grandi data center).

Commutazione di Pacchetto (Packet Switching)

I dati vengono spezzettati in pacchetti, ognuno dei quali può fare strade diverse per arrivare a destinazione.

Oggi giorno si usa il **MPLS** (Multi-Protocol Label Switching) in quanto più veloce perché i router non leggono l'indirizzo IP completo ad ogni incrocio ma una piccola label (etichetta). Questo rende il passaggio dei dati velocissimo.

MPLS non passa sulla rete pubblica ma usa una rete privata.

VPN su rete pubblica

Viene usata una VPN che fa viaggiare i dati all'interno di tunnel.

Viene sfruttata una normale connessione Internet per creare un tunnel IPsec.

Firewall

Firewall

Definizione

Il Firewall è un sistema informatico che applica delle policy (regole) di sicurezza per controllare, monitorare e filtrare il traffico in uscita (egress filtering) e in entrata (ingress filtering) nei vari livelli dello stack OSI di una rete.

Le sue funzioni principali sono:

- **Filtraggio dei pacchetti:** analizza ogni pacchetto che transita sulla rete;
 - **Blocco degli accessi non autorizzati:** impedisce ad hacker o software malevoli di accedere alla rete;
 - **Controllo delle applicazioni:** può impedire a specifici programmi di connettersi alla rete.
-

Policy

Ogni firewall opera seguendo delle regole, dette policy. Ci sono due filosofie:

- **Permissive Policy (default allow):** Tutto ciò che non è esplicitamente vietato è permesso;
 - **Restrictive Policy (default deny):** Tutto ciò che non è esplicitamente permesso è vietato (più usato).
-

Tipologia di Firewall

I firewall si dividono in base alla minaccia che devono affrontare:

1) *Packet Filtering*

Controlla l'IP di destinazione/origine, porte e protocollo del pacchetto, ma è facile da ingannare in quanto basta mandare un pacchetto malevolo su una porta consentita.

2) *Stateful Inspection*

Tiene traccia dello stato delle comunicazioni attive.

Crea una "tabella di stato" e controlla se un pacchetto esterno che arriva fa parte di essa.

3) *Proxy Firewall*

Questo firewall agisce a livello applicativo (7) e non permette una connessione diretta tra mittente e destinatario.

Quando un PC vuole connettersi a un sito, la richiesta viene ricevuta ed esaminata dal Proxy. Successivamente, essa verrà "impacchettata" in un pacchetto avente come indirizzo IP quello del Proxy Firewall. Il sito risponde al proxy e il proxy inoltra la risposta al PC.

Questo tipo di firewall può filtrare contenuti specifici quali bloccare certi siti o impedire il download di certi tipi di file (come quelli .exe)
Può rallentare, però, la navigazione.

4) Next Generation Firewall (NGFW)

È il firewall più usato nelle aziende. Unisce le funzioni dei firewall precedenti e agisce dal livello 3 al 7. Gli strumenti che usa sono:

- **Deep Packet Inspection (DPI):** Analizza il payload del pacchetto e tutto ciò che trasporta in tempo reale.
- **Intrusion Prevention System (IPS):** Rileva e blocca possibili attacchi analizzando non i singoli pacchetti ma le intere conversazioni.
- **Sandboxing:** Se riceve un file sospetto, lo esegue in ambiente isolato (in una sandbox) per vedere se si comporta in modo malevolo. Può causare ritardo.

Firewall Hardware e Software

Un **Software Firewall** è un software installato sul singolo computer (come Windows Defender) che protegge solo il dispositivo stesso.

Un **Hardware Firewall** è un dispositivo fisico posizionato tra modem e il resto della rete. Protegge tutti i dispositivi collegati contemporaneamente.

Internet Security

Internet Security

Definizione

L'Internet Security è l'insieme di misure utilizzate per proteggere i dati durante la loro trasmissione sulla rete internet.

Essa si basa sul documento Recommendation X.800 Security Architecture.

I requisiti imposti da questo documento, nonché i pilastri della sicurezza, sono:

- **Confidenzialità**: riservatezza dei dati;
 - **Integrità**;
 - **Autenticazione**: assicurarsi dell'identità dei soggetti coinvolti;
 - **Controllo degli accessi**: niente accessi non autorizzati;
 - **Non ripudio**: non si può negare la paternità di un azione.
-

Information Hiding

L'Information Hiding è la disciplina che racchiude varie tecniche utilizzate per nascondere dati all'interno di altri dati.

Essa comprende:

- **Crittografia**;
- **Steganografia**;
- **Watermarking**.

Crittografia

Crittografia

Definizione

La crittografia è un insieme di procedure ideate allo scopo di nascondere il significato di un messaggio a tutti tranne che al legittimo destinatario.

La crittografia, in generale, si basa su cifrari o codici.

Un **cifrario** è un algoritmo matematico usato per trasformare un messaggio in chiaro in un messaggio cifrato e viceversa, per garantire riservatezza.

Un **codice** è un sistema di regole che attribuisce a un determinato carattere un significato preciso. Dipende strettamente dal contesto in cui viene usato.

In ambito informatico parliamo ovviamente sempre di cifratura (quindi si usano i cifrari).

Nella cifratura possiamo distinguere 4 soggetti:

- **Plain Text (messaggio in chiaro)**: messaggio che vogliamo nascondere;
 - **Cifrario**: è l'algoritmo di cifratura che usiamo;
 - **Chiave**: è una sequenza di bit di lunghezza finita, generata in modo casuale, usata come ingresso di un algoritmo di cifratura avente l'uscita dipendente da essa;
 - **Chiper Text (messaggio cifrato)**: messaggio nascosto.
-

Principi di Cifratura

Nella crittografia ci sono due principi fondamentali:

1) Principio di Kerckhoffs

Secondo Kerckhoffs: "la sicurezza di un sistema crittografico non sta nel tenere celato l'algoritmo ma la chiave".

Quindi l'importante è tenere la chiave segreta.

2) Principio di Shannon

È un'evoluzione del principio di Kerckhoffs. Egli dimostrò che esiste solo un modo per ottenere la sicurezza perfetta ed è il one time pad, in cui la chiave:

- **Lunga almeno quanto il messaggio da cifrare**;
- **Veramente casuale** (generata da fenomeni fisici e non da pc);
- **Usata una sola volta** e poi distrutta.

Se la chiave è generata davvero casualmente allora avrà la massima entropia perché non ci sono schemi che si ripetono e il messaggio cifrato sarà puro rumore.

Secondo Shannon, un cifrario per essere sicuro deve usare:

- **Diffusione**: nascondere le strutture statistiche del messaggio tramite trasposizione;
 - **Confusione**: serve a rendere la relazione chiave-testo cifrato il più complessa possibile, usando la sostituzione.
-

Classificazione delle Tecniche di Cifratura

I sistemi crittografici possono essere classificati in vario modo, in base al:

1) Tipo di operazioni usate per trasformare il testo

- **Crittografia a sostituzione:** ogni elemento del testo in chiaro viene trasformato in un altro;
- **Crittografia a trasposizione:** gli elementi del testo in chiaro vengono riorganizzati.

Questa separazione è un po' vecchia in quanto nei cifrari moderni, spesso si usano entrambe le tecniche.

2) Modo in cui il testo è elaborato

- **Crittografia a blocchi:** il testo viene suddiviso in blocchi da N bit e ogni blocco viene elaborato in modo indipendente dagli altri;
- **Crittografia a flusso:** cifra i dati un bit o byte alla volta, combinandoli con una sequenza di numeri pseudo-casuali chiamata keystream.

3) Numero di chiavi

- **Crittografia a chiave simmetrica:** la chiave del mittente e del destinatario è uguale;
 - **Crittografia a chiave asimmetrica:** in questo sistema, ogni utente ha una coppia di chiavi: una pubblica e una privata.
-

Crittografia Simmetrica

La crittografia a chiave simmetrica (o a chiave singola) si basa sull'utilizzo di una sola chiave segreta condivisa tra mittente e destinatario usata per cifrare e decifrare i messaggi.

Il principale problema di questo sistema è la gestione della chiave: deve essere condivisa in modo sicuro prima della comunicazione, altrimenti può essere intercettata.

Inoltre non garantisce il non ripudio, perché entrambe le parti conoscano la stessa chiave e non è possibile attribuire in modo preciso la paternità della creazione di un messaggio. Per garantire autenticazione e integrità, vengono spesso utilizzati meccanismi aggiuntivi come MAC (Message Authentication Code).

Crittografia Asimmetrica

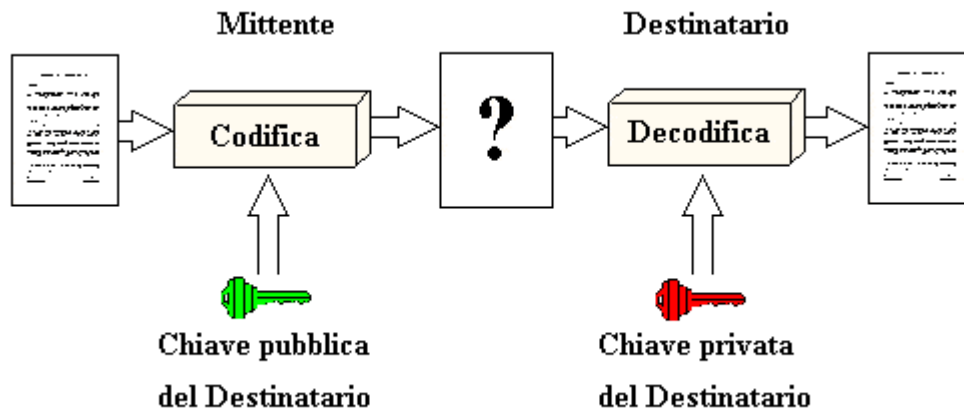
La crittografia a chiave asimmetrica (o a doppia chiave), prevede l'uso di una coppia di chiavi per utente:

- **Chiave pubblica:** è distribuita liberamente e viene utilizzata per cifrare i messaggi o verificare le firme digitali;
- **Chiave privata:** viene mantenuta segreta e viene usata per decifrare i messaggi o generare firme digitali.

Le due chiavi sono matematicamente correlate in modo che ciò che viene cifrato con una chiave può essere decifrato solo con l'altra.

Questa crittografia nasce per risolvere il problema dello scambio non sicuro delle chiavi. Inoltre, se combinata con firme digitali, può garantire integrità, non ripudio e autenticazione. La confidenzialità del sistema è garantita quando viene utilizzata la cifratura.

Per far sì che un utente non si sostituisca ad un altro usando la sua chiave pubblica, nascono le Certification Authority: enti che hanno il compito di collegare una chiave pubblica a un'identità verificata tramite certificati digitali.



Generazione delle chiavi

La generazione delle chiavi è il processo attraverso cui si creano le chiavi crittografiche utilizzate negli algoritmi di cifratura.

Una chiave, come abbiamo visto prima, deve essere:

- realmente casuale;
- unica (non riusata);
- sufficientemente lunga.

Per generare chiavi sicure si utilizzano i CSPRNG (Cryptographically Secure Pseudo Random Number Generator): generatori pseudo-casuali progettati per essere imprevedibili. Essi usano valori di natura casuale del sistema, come la latenza nella rete, la velocità dell'hard-disk, il tempo che passa tra un clic e l'altro sulla tastiera, differenze elettriche interne al computer, lo spostamento del mouse...

La sicurezza di una chiave dipende dalla sua entropia, ovvero dal grado di imprevedibilità.

Per la generazione e lo scambio di una chiave di sessione, spesso si utilizza un key exchange protocol, come Diffie-Hellman.

Le chiavi verranno memorizzate in modo sicuro, spesso su HSM (Hardware Security Module) o per quanto riguarda i nostri pc su TPM (Trusted Platform Module - piccolo chip saldato sulla scheda madre).

Devono essere usate solo per lo scopo previsto e vanno periodicamente cambiate e distrutte in modo sicuro.

Certificati Digitali e Firma Digitale

Un certificato digitale è un documento elettronico che associa una chiave pubblica all'identità di un soggetto.

Serve a risolvere il problema principale della crittografia asimmetrica facendoci sapere se una chiave pubblica appartiene davvero a chi dice di essere il proprietario.

Un certificato digitale contiene:

- chiave pubblica del soggetto;
- informazioni sull'identità del soggetto;
- periodo di validità;
- firma digitale dell'ente certificatore.

La firma digitale garantisce l'integrità e l'autorità del certificato.

Certification Authority

La Certification Authority è un ente fidato che ha il compito di emettere, verificare e gestire i certificati digitali.

Il suo ruolo è quello di:

- Verificare l'identità del richiedente;
- Associare in modo sicuro la chiave pubblica all'identità;
- firmare il certificato digitale.

C'è una gerarchia nelle CA: la più importante è la Root CA che firma altre CA che a loro volta possono firmare altre CA.

PKI

La PKI (Public Key Infrastructure) è l'insieme di regole, enti e tecnologie che permettono la gestione dei certificati digitali e delle chiavi pubbliche.

Firma Digitale

Non si firma il documento direttamente, ma una sua impronta.

La creazione di una firma digitale prevede più passaggi:

1) Calcolo dell'hash

Il documento viene elaborato tramite una funzione di hash crittografica.

La funzione di hash è una funzione unidirezionale che trasforma il documento di lunghezza variabile in un'impronta di lunghezza fissa. È progettato per essere irreversibile e sensibile a qualsiasi modifica del documento.

2) Cifratura dell'hash

L'hash ottenuto viene cifrato con la chiave privata del mittente. Questo passaggio è la firma vera e propria.

3) Invio del documento

Si invia il documento originale e la firma digitale.

Per verificare la firma, si usa la chiave pubblica del mittente per decriptare l'hash e ottenere quello originale. Successivamente si calcola di nuovo l'hash. Se i due combaciano, il documento è integro e autentico, se non combaciano significa che il documento è stato modificato o la firma è falsa.

Algoritmi di Cifratura

DES

Il Data Encryption Standard è uno dei primi algoritmi di cifratura simmetrica diventati standard industriali. Utilizza la stessa chiave per cifrare e decifrare i dati e lavora a blocchi da 64 bit con una chiave effettiva di 56 bit. La sua sicurezza si basa su una rete di Feistel: una struttura iterativa (che si ripete più volte) che mescola ripetutamente sostituzioni e permutazioni tra i blocchi (divideva ogni blocco in due metà e le mescolava). Effettua 16 round di trasformazioni.

Oggi DES non è più sicuro perché la lunghezza della chiave è troppo corta. Hanno anche provato a inventare il Triple DES, che usava il DES tre volte, ma anche questo aveva molti contro per essere usato oggi.

AES

L'Advanced Encryption Standard è lo standard moderno per la cifratura simmetrica. È un algoritmo a blocchi con dimensione fissa di 128 bit e supporta chiavi da 128, 192 e 256 bit. A differenza del DES, AES non usa una rete di Feistel ma una SPN (Substitution-Permutation Network).

Esso si basa su più round di trasformazioni (dipendono dalla chiave usata: parte da 10 fino a 14 round) che includono sostituzioni dei byte, permutazioni e operazioni matematiche su campi finiti. Questo rende AES molto resistente agli attacchi crittografici conosciuti.

AES non viene usato direttamente da solo, ma si usa tramite modalità operative. La più recente e migliore è la GCM. AES-GCM non solo cifra i dati, ma ne garantisce anche l'integrità tramite autenticazione. Ad oggi è la scelta principale nei protocolli come TLS.

Diffie-Hellman

Diffie-Hellman è un protocollo per lo scambio sicuro di chiavi su un canale pubblico. La sua idea è che due parti possano generare una chiave condivisa senza mai trasmetterla direttamente.

Il funzionamento si basa sulla matematica modulare e sull'impossibilità pratica di risolvere il logaritmo discreto. Ogni parte sceglie un valore privato, calcola un valore pubblico e lo scambia. A partire da questi valori pubblici e dal proprio segreto, entrambe le parti arrivano allo stesso risultato finale che diventa la chiave condivisa.

Va sempre affiancato ad un'autenticazione per evitare attacchi MITM.

Nella pratica moderna, però, si preferisce usare ECDH: una versione di Diffie-Hellman basata sulle curve ellittiche che offre la stessa sicurezza ma con chiavi più piccole e prestazioni migliori.

RSA

RSA è uno dei primi sistemi crittografici asimmetrici e si basa sulla difficoltà di fattorizzare numeri grandi. La sicurezza deriva dal fatto che è facile moltiplicare due numeri primi grandi, ma è difficile risalire ai fattori originali.

Il sistema funziona generando una coppia di chiavi a partire da due numeri primi. Il prodotto di questi numeri diventa parte della chiave pubblica, mentre una seconda componente matematica permette di costruire la chiave privata.

Le chiavi hanno una lunghezza minima di 2048 bit, ma esistono chiavi anche da 3072 e 4096 bit.

RSA può essere usato per cifratura, firma digitale e scambio di chiavi, ma è molto più lento rispetto ai sistemi crittografici simmetrici. Per questo RSA si usa spesso solo per scambiare la chiave simmetrica, mentre il resto della cifratura viene effettuata con AES.

ECC

Come nello stesso caso dei sistemi Diffie-Hellman, RSA è stato sostituito da ECC: un sistema che usa la crittografia a curve ellittiche, permettendo di mantenere lo stesso livello di sicurezza ma con chiavi più piccole e operazioni più veloci.

ECC è diventato lo standard moderno in molti sistemi perché è più efficiente in termini di calcolo e di banda. Viene usato soprattutto per lo scambio di chiavi ECDH.

Hash Crittografici

Una funzione di hash prende un input di qualsiasi dimensione e produce un output fisso chiamato digest. La proprietà fondamentale è che il processo è unidirezionale: non è possibile risalire all'input originale a partire dall'hash.

Inoltre, lo stesso input deve produrre sempre lo stesso output.

Una collisione avviene quando due input diversi hanno lo stesso output. Se esistono collisioni, l'algoritmo è compromesso.

La funzione di hash più usata oggi è la SHA-256.

SHA-256 produce un output da 256 bit.

Funziona dividendo il messaggio in blocchi da 512 bit.

Poi applica molte trasformazioni bit a bit e aggiorna continuamente uno stato interno.

Le operazioni bit a bit includono XOR, rotazioni e somme modulari.

Crittoanalisi

La crittoanalisi è un insieme di tecniche che servono a testare la robustezza dell'algoritmo di cifratura e della chiave cercando di trovare quest'ultima partendo solo dai testi cifrati disponibili.

Esistono due tipi di attacchi ai cifrari:

- **Attacchi Criptonalitici:** si attacca usando la crittoanalisi (sfruttando le conoscenze sull'algoritmo e sul messaggio cifrato);
- **Attacchi brute force:** si provano tutte le chiavi possibili su quel testo cifrato. Per rendere tutto più veloce bisogna conoscere una parte del messaggio in chiaro.

Steganografia e Watermarking

Steganografia e Watermarking

Steganografia

La steganografia è l'insieme delle tecniche che permettono di nascondere l'esistenza di un messaggio o la comunicazione stessa.

La steganografia fallisce se il tentativo di scambio del messaggio viene scoperto, anche se non si è in grado di decrittare il contenuto.

La steganografia più usata è quella sostitutiva: sostituiamo parti "insignificanti" di un file con parti del messaggio segreto.

La tecnica steganografica a sostituzione più usata è la LSB (Least Significant Bit): prendiamo il bit meno importante di un colore di un pixel e lo cambiamo così che il colore vari di una frazione impercettibile.

Watermarking

Il watermarking è una tecnica che consiste nel inserire informazioni in contenuti multimediali in modo che siano difficilmente rimovibili e, spesso, invisibili.

È usato principalmente per dimostrare l'originalità e chi è il proprietario.

Reti Wireless

Reti Wireless

Definizione

Sono delle reti che collegano i dispositivi al loro interno tramite onde radio o infrarossi, eliminando l'uso dei cavi fisici.

Come funzionano

La rete wireless si basa sulla conversione dei dati digitali (0 o 1) in segnali radio.

A questo scopo possiamo dividere due funzioni:

- **Trasmissione:** un dispositivo (come un router) traduce i dati in segnale radio tramite un'antenna;
- **Ricezione:** un dispositivo riceve il segnale e lo riconverte in dati digitali.

Questi segnali viaggiano su frequenze specifiche, misurate in Hertz (Hz). Le più comuni e usate sono le bande a 2,4 GHz (più lenta ma con raggio d'azione maggiore) e 5 GHz (più veloce ma con raggio d'azione ridotto).

Standard Wi-Fi (Principali)

Ci sono diversi "tipi" di Wi-Fi:

- Wi-Fi 5 (802.11ac): lo standard più diffuso;
 - Wi-Fi 6 (802.11ax): progettato per gestire molti dispositivi contemporaneamente con maggiore efficienza energetica;
 - Wi-Fi 7 (802.11be): la tecnologia più moderna con velocità teoriche superiori ai 40Gbps e latenza bassissima.
-

Vantaggi e Svantaggi

Vantaggi

- **Mobilità:** puoi connetterti ovunque ci sia copertura;
- **Scalabilità:** aggiungere un nuovo utente alla rete è immediato;
- **Costi ridotti:** soprattutto negli edifici storici in cui sarebbe difficile o impossibile far passare i cavi.

Svantaggi

- **Sicurezza:** i segnali radio viaggiano nell'aria e possono essere intercettati da tutti;
- **Interferenze:** muri spessi, microonde o anche altre reti Wi-Fi possono disturbare il segnale;
- **Velocità ridotta:** una connessione ethernet rimane la più veloce.

Tipologia reti Wireless

Tipologia reti Wireless

WPAN

Definizione

Le WPAN sono reti a cortissimo raggio che connettono dispositivi personali attorno a un singolo utente.

Componenti Principali

- **Master:** il dispositivo principale che controlla la connessione (es. telefono o pc);
- **Slave:** il dispositivo che si connette al master.

Modalità di Funzionamento

- **Piconet:** una piccola rete formata da un master e fino a 7 slave attivi;
 - **Scatternet:** l'unione di più piconet comunicanti tra loro.
-

WLAN

Definizione

Le WLAN (Wireless Local Area Network) sono delle reti locali che usano onde radio per connettere i dispositivi invece che usare cablaggi fisici (Ethernet). Lo standard più diffuso è il 802.11 (Wi-Fi).

Componenti Principali

Per far funzionare una WLAN servono due componenti:

- Access Point (AP): Riceve il segnale via cavo e lo trasmette nell'aria;
- Station (STA): Qualsiasi dispositivo dotato di scheda wireless che si connette all'AP.

Parametri di Configurazione di un Access Point

La configurazione di un AP prevede di scegliere:

- SSID (nome della rete);
- Protocollo di sicurezza;
- Canale e Banda (es. 2.4GHz o 5GHz);
- Eventuale MAC Filter (filtra i dispositivi in base al loro MAC).

Modalità di Funzionamento

Esistono due modalità di funzionamento delle WLAN:

- **Infrastructure Mode:** Configurazione classica in cui tutti i dispositivi passano per l'AP;
- **Ad-Hoc Mode:** Connessione diretta tra STA (peer to peer).

Architetture

Ci sono due principali architetture delle WLAN che vanno in base al numero di AP:

- **BSS (Basic Service Set)**: È composta da un solo AP e dalle STA. Ogni BSS ha in BSSID, che è il MAC della scheda radio dell'AP. L'area coperta dalla BSS viene detta BSA (Basic Service Area).
 - **ESS (Extended Service Set)**: Composta da più AP collegati fra loro (spesso via Ethernet). Tutti gli AP dell'ESS hanno lo stesso SSID per permettere il Roaming. Così possiamo passare da un AP all'altro senza problemi.
-

WMAN

Definizione

Le WMAN sono reti progettate per coprire aree geografiche di dimensioni urbane. Spesso vengono usate come "ultima speranza" per fornire internet dove non è possibile posare cavi.

Componenti Principali

Le WMAN hanno due componenti principali:

- **Base Station (BS)**: una torre di trasmissione centrale;
- **Subscriber Station (SS)**: l'antenna ricevente installata presso l'utente finale.

Parametri da Gestire

Nelle WMAN è importante gestire questi parametri:

- Line of Sight (LoS): la necessità che non ci siano ostacoli fisici tra BS e SS;
- Settore: è la porzione di territorio coperta da una singola antenna sulla torre;
- QoS (Quality of Service): gestione della priorità del traffico.

Architetture

Ci sono due architetture principali:

- Point-to-Multipoint (PMP): una singola stazione base serve molti utenti;
 - Mesh metropolitana: i vari nodi della rete rilanciano il segnale tra loro.
-

WWAN

Definizione

Le WWAN coprono aree vastissime. Si appoggiano su infrastrutture di operatori telefonici o satelliti.

Componenti Principali

- **Core Network**: l'infrastruttura centrale dell'operatore che gestisce i dati;
- **Cell Tower (BTS/NodeB)**: sono torri sparse sul territorio che creano le "celle" di copertura;
- **SIM/eSIM**: il modulo di identificazione necessario per accedere alla rete.

Attacchi alle Reti Wireless

Attacchi alle Reti Wireless

Gli attacchi alle reti wireless possono essere divisi in diverse categorie in base all'obiettivo dell'attaccante:

- Attacchi di intercettazione: mirati a violare la riservatezza dei dati;
 - Attacchi di accesso non autorizzato: mirano ad entrare nella rete;
 - Attacchi basati sulla manipolazione (Man-In-The-Middle): per intercettare o modificare comunicazioni;
 - Attacchi di interruzione del servizio (DoS): colpiscono la disponibilità della rete;
 - Attacchi ai client e Social Engineering;
-

Attacchi di Intercettazione (Eavesdropping)

Come funzionano

Si sfrutta la natura omnidirezionale delle onde radio (vanno ovunque). Un attaccante usa la "modalità monitor" della sua scheda di rete catturando tutti i pacchetti che transitano nell'area.

Esempi

1) Sniffing

L'attaccante utilizza software di analisi dei pacchetti (come Wireshark) per catturare i pacchetti dati che viaggiano nell'aria. Se il traffico non è criptato o ha una crittografia debole, è possibile leggere le informazioni scambiate.

2) Analisi del traffico

Anche se i dati sono criptati, un attaccante può dedurre informazioni osservando caratteristiche come volume, frequenza e destinazione dei pacchetti.

Contromisure

Sicuramente è fondamentale usare una crittografia forte affidandosi a meccanismi come WPA3 o come minimo WPA2.

L'uso di una VPN può essere una buona contromisura in quanto i dati viaggiano nel tunnel IPsec.

Preferire protocolli sicuri come HTTPS, IMAPS o SMTPS.

Attacchi di Accesso (Cracking)

Come funzionano

L'attaccante cattura l'handshake e tenta miliardi di combinazioni di password "offline" per trovare quella giusta. Questa pratica si chiama Brute Force (forza bruta) o Dictionary quando si usano dizionari contenenti le possibili password.

Esempi

Cracking delle password con WEP (molto veloce) o WPA/WPA2/WPA3 in cui si prova a eseguire brute force o dictionary per indovinare la chiave precondivisa (PSK).

Spesso si usa anche una vulnerabilità del WPS (WiFi Protected Setup), che è una funzionalità che serve a connettere rapidamente i dispositivi alla rete wireless senza inserire la password manualmente, per ottenere l'accesso senza conoscere la password.

Contromisure

Usare password robuste, usare WPA3 che introduce SAE [\[Sicurezza reti Wireless\]](#) e disabilitare il WPS.

Attacchi basati sulla Manipolazione (MITM)

Come funzionano

Si basano sul principio di Man in the middle (MITM): l'attaccante si posiziona tra la vittima e il punto di accesso (AP) per intercettare o modificare le comunicazioni.

Esempi

1) Evil Twin

L'attaccante crea un punto di accesso falso con lo stesso nome (SSID) di una rete legittima. Gli utenti si connetteranno ignari al dispositivo dell'attaccante.

2) Rogue Access Point

Viene installato fisicamente un punto di accesso non autorizzato all'interno di una rete aziendale per aggirare i controlli di sicurezza perimetrali.

Contromisure

Usare tecnologie enterprise che permettono al client di verificare l'identità del server attraverso certificati digitali.

Si può anche disabilitare l'auto-join che collega i dispositivi automaticamente a reti note ma non protette.

Attacchi di Interruzione del Servizio (Denial of Service)

Come funzionano

Questi tipi di attacchi si basano spesso sulla Deauthentication: viene inviato un pacchetto "death" con l'indirizzo MAC contraffatto del router al dispositivo della vittima che crederà che il router lo stia disconnettendo e interrompe la sessione.

Esempi

1) Jamming

Utilizzo di dispositivi che emettono forti segnali radio sulle stesse frequenze del Wi-Fi (2,4GHz o 5GHz) per saturare il segnale legittimo e causare interferenze totali.

2) Deauthentication Attack

Si basa sulla tecnica di "deauth" descritta sopra.

Contromisure

WPA3 integra la funzione di Management Frame Protection (standard IEEE 802.11w) che cifra i pacchetti di gestione (come la disconnessione) impedendo a terzi di falsificarli. Un altro modo è quello di usare IPS.

Attacchi ai Clienti e Social Engineering

Come funzionano

Questi tipi di attacchi non sfruttano debolezze dei software, ma la fiducia dell'utente.

Esempi

1) Captive Portal Phishing

Una volta che ti sei connesso a una rete (spesso Evil Twin), il tuo browser apre automaticamente una pagina di login (Captive Portal) simile a quella degli hotel o aeroporti per esempio. Qui la pagina chiederà di autenticarti (magari con email e password di google) ma i dati verranno inviati al server dell'attaccante.

Esiste anche una variante che ti chiede di aggiornare il browser o scaricare un certificato di sicurezza, ma che in realtà ti installa un trojan o un altro tipo di malware.

Contromisure

Svegliarsi e stare attenti a ciò che clicchi o a ciò che ti colleghi.

Sarebbe una buona pratica usare una VPN e autenticazione a due fattori.

Un'altra cosa utile sarebbe disattivare il Wi-Fi quando non serve per evitare che il tuo telefono dica costantemente i nomi delle tue reti di casa alle quali sta cercando di connettersi.

Sicurezza reti Wireless

Sicurezza reti Wireless

Una rete wireless che non implementa crittografia e autenticazione è una rete aperta a chiunque sia nel range dell'AP. Perciò esse sono il pilastro della sicurezza delle reti wireless:

- **Autenticazione:** procedura con la quale si verifica se il dispositivo che si vuole connettere alla rete è autorizzato;
 - **Crittografia:** procedura che rende leggibili i dati solo a chi ha la corretta chiave di decifrazione.
-

WEP (Wired Equivalent Privacy)

WEP è stata la prima tecnica crittografica di default del protocollo IEEE 802.11 (Wi-Fi)

È stato il primo tentativo di protezione per autenticare i dispositivi tramite password.

L'obiettivo era quello di raggiungere un livello di sicurezza equivalente a quello delle reti cablate.

Crittografia

Il WEP usa un algoritmo di cifratura a flusso a chiave simmetrica chiamato RC4 (Rivest Cipher). La chiave era la password che noi decidevamo.

Il WEP, per ogni pacchetto inviato, combina la nostra password con un IV (Vettore di Iniziazione) a 24 bit, nonché un piccolo codice, per generare un keystream RC4.

Il WEP è stato rotto in quanto il IV è di soli 24 bit e la password non cambia mai automaticamente. Un hacker può raccogliere abbastanza pacchetti per calcolare la chiave originale in pochissimo tempo.

Autenticazione

Il WEP prevede due sistemi di autenticazione.

1) Open System

Tutti i dispositivi nel range dell'AP possono tentare di accedere alla rete senza alcun tipo di autenticazione. Per niente sicuro

2) Shared Key

Consente di autenticare un dispositivo tramite password usando un meccanismo

Challenge-Response:

1. **Challenge:** il client chiede di autenticarsi all'AP. L'AP gli manda un testo in chiaro di stringhe casuali di 128 byte;
 2. **Response:** Il client prende il testo in chiaro e lo cripta usando la chiave WEP (la password della rete) e l'algoritmo di cifratura (RC4);
 3. **Verifica:** L'AP decripta il messaggio del client con la chiave WEP corretta. Se il messaggio è identico autentica il dispositivo;
 4. **Conferma:** L'AP manda un messaggio di conferma al dispositivo (messaggio ACK).
-

WPA (Wifi Protected Access)

WPA nasce per colmare le lacune del WEP.

Crittografia

WPA usa TKIP (Temporal Key Integrity Protocol) come protocollo crittografico, che a sua volta usa RC4 ma con chiavi crittografiche a 128 bit e un vettore di inizializzazione (IV) a 48 bit. Il TKIP introduce il per-packed key mixing: la chiave crittografica cambia dinamicamente per ogni singolo pacchetto di dati inviato.

Usa anche MIC (Message Integrity Check) per garantire l'integrità dei messaggi scambiati.

Autenticazione

Per l'autenticazione, anche WPA ha due metodi:

1) WPA Personal (WPA-Personal)

Pensato per le case. Usa una password comune per tutti (Pre-Shared Key) su cui poi avviene il 4 Way Handshake:

1. **Challenge:** Il router genera un numero casuale (ANonce) e lo manda al client;
2. **Response:** Il client genera un numero casuale (SNonce) e, combinandosi con la password e l'ANonce crea la chiave finale (PTK). Infine manda il suo SNonce e un MIC per dire al router che ha la password corretta.
3. **Verifica:** Il router genera a sua volta la PTK e, se tutto va bene, il router invia al client un messaggio di conferma e una GTK (chiave del gruppo) per le connessioni broadcast o multicast.
4. **Conferma:** Il client manda un messaggio di conferma.

2) WPA Enterprise (WPA802.1X)

È pensato per le aziende. Non c'è una password unica per tutti. Ogni utente si collega alla rete con le proprie credenziali (nome utente e password) gestite e verificate da un server RADIUS.

WPA2 (Wifi Protected Access version 2)

WPA2 nasce come versione migliore di WPA. Essa usa algoritmi di cifratura e integrità più forti.

Crittografia

WPA2 non usa più TKIP come protocollo di sicurezza, ma usa CCMP (Counter-mode with CBC-MAC Protocol).

CCMP usa l'algoritmo di cifratura AES che, a differenza del RC4, non è un algoritmo a flusso ma a blocchi simmetrico

AES supporta chiavi crittografiche di 128, 192 e 256 bit. Di solito si usa una da 128.

Per lavorare sull'integrità, il CCMP genera un MIC più complesso e aggiunge un PN (Packet Number): un numero di sequenza che aumenta sempre di 1.

Con il PN, se un hacker dovesse catturare un pacchetto e rimandarlo successivamente, il router vedrebbe il PN vecchio e lo rifiuterebbe.

Autenticazione

È uguale a quella del WPA: quindi anche qui c'è la divisione tra personal ed enterprise.

L'unica differenza è che con WPA2, le chiavi usate durante il 4 way handshake sono generate con CCMP e AES invece che TKIP.

Svantaggi

È vulnerabile ad attacchi KRACK (Key Reinstallation Attack) e brute force con dizionari offline (puoi provare quante volte vuoi).

L'attacco KRACK "rompe" il WPA2 catturando un pacchetto inviato dal router al client. Dato che il router non riceve nulla in risposta, ne invierà un altro. Inoltrando tutti questi messaggi al client, WPA2 costringeva il client a reinstallare la stessa chiave e a resettare i PN. Questo "reset" rompe la crittografia WPA2.

WPA3 (WiFi Protected Access version 3)

WPA3 nasce per rendere ancora più sicuro il WPA2 e offre pieno supporto ai dispositivi IoT. Sono state implementate 4 innovazioni:

- 1) **SAE (Simultaneous Authentication of Equals)**: sostituisce il 4-way handshake obbligando l'attaccante a dover interagire con il router a ogni singolo tentativo e non potendo più tentare offline catturando l'handshake. Dopo alcuni tentativi, il router blocca il dispositivo.
 - 2) **Forward Secrecy**: ogni sessione ha una chiave unica che non dipende dalla password principale. Quindi se un hacker dovesse registrare il traffico WI-Fi e scoprisse la password domani, non potrebbe decifrare i messaggi scambiati oggi.
 - 3) **OWE (Opportunistic Wireless Encryption)**: qualsiasi connessione (anche se senza password) verrà crittografata, ma non per forza autenticata.
 - 4) **Crittografia a 192 bit (Enterprise)**: per la versione enterprise del WPA 3 si usa una chiave crittografica a 192 bit, rendendolo difficile da decifrare.
-

RADIUS e framework AAA

Il **framework AAA** (Authentication Authorization Accounting) è un concetto che descrive i tre passaggi per gestire la sicurezza e l'accesso degli utenti in un sistema informativo.

RADIUS (Remote Authentication Dial-In User Service) è un protocollo che implementa il framework AAA. Funziona tipicamente con un architettura client/server:

- **L'utente:** cerca di connettersi a una risorsa (es. Access Point);
- **Client RADIUS (NAS):** il dispositivo di rete (es. router, AP o switch) inoltra la richiesta al server;
- **Server RADIUS:** riceve la richiesta, consulta il database con le informazioni degli utenti e risponde con un messaggio "Access-accept" o "Access-Reject".

Come protocollo di trasporto si usa l'UDP (porta 1812 per autenticazione e 1813 per accounting). Per quanto riguarda la sicurezza, RADIUS cifra solo la password e non l'intero pacchetto.

Il protocollo RADIUS, quindi, serve a gestire in modo centralizzato l'accesso alle reti, offrendo autenticazione, autorizzazione e tracciamento. Il RADIUS spesso accoppia Autenticazione e Autorizzazione.

TACACS+ *

Se si vuole una maggiore controllo e sicurezza al prezzo di una velocità di risposta ridotta, si può optare per l'uso del protocollo **TACACS+**.

Anche TACACS+ implementa il framework AAA, usando però per la comunicazione il protocollo TCP al posto dell'UDP. TACACS+ inoltre offre un maggiore livello di sicurezza in quanto cripta non solo la password ma l'intero pacchetto.

Un'altra differenza rispetto al RADIUS è che TACACS+ tiene separate le funzioni di Autorizzazione e Autenticazione.

TACACS+ è usato più per l'accesso amministrativo ai dispositivi (router, switch...).

VLAN

VLAN

Definizione

Le VLAN sono sottoreti logiche create da switch, indipendenti dalla connessione fisica. La funzione principale è quella di segmentare la rete locale (LAN) in più domini di broadcast separati.

Vantaggi

Le VLAN offrono tanti tipi di vantaggi:

- **Riduzione del traffico in rete**, dato che si dividono i domini di broadcast;
 - **Sicurezza**, in quanto le sottoreti sono isolate tra di loro e hanno ognuno una porta diversa;
 - **Migliore gestione della rete**, in quanto le reti possono essere divise in base all'ambito in cui opereranno o altre caratteristiche (es. vlan ospiti, admin...);
 - **Flessibilità**, perché è semplice spostare o aggiungere host senza ricablare la rete;
 - **Costi ridotti**, perché serve un dispositivo per creare più reti.
-

VLAN ID e Assegnazione

Una VLAN è identificata da un VLAN ID (che va da 1 a 4094, quindi è lungo 12 bit). Il VLAN ID è contenuto all'interno di un "tag" nel frame ethernet. Lo standard per questo processo è l'IEEE 802.1Q. Solitamente:

- *VLAN 1* è quella predefinita (di default) su quasi tutti gli switch.
- *Native VLAN* è la VLAN che gestisce il traffico "non taggato".

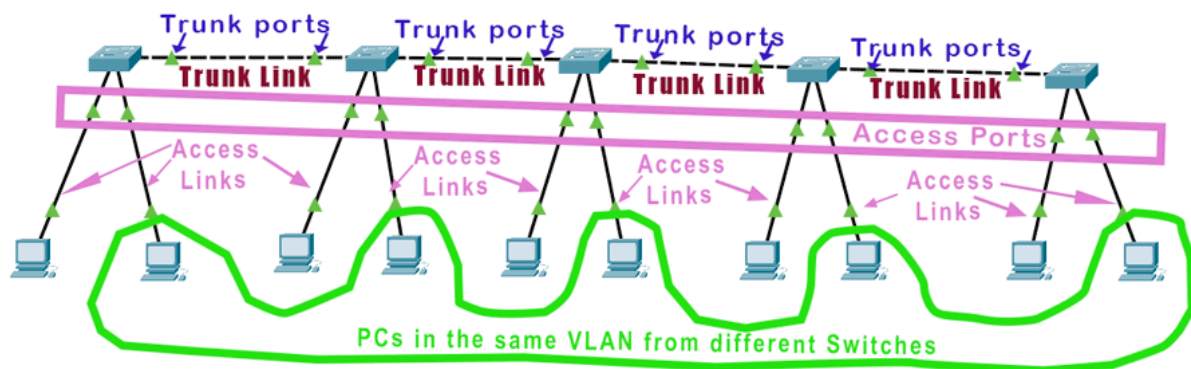
L'assegnazione degli host a una VLAN può avvenire in tre modi:

- **Port-Based**: viene assegnata una porta specifica per ogni VLAN ID;
 - **MAC-Based**: i MAC dei dispositivi sono registrati in una tabella con associato il proprio VLAN ID;
 - **Protocol-Based**: Viene stabilita una VLAN per un protocollo, successivamente lo switch analizza il contenuto del frame ethernet (nello specifico il campo EtherType) per determinare il protocollo di rete utilizzato e associarlo, quindi, alla VLAN stabilita.
-

Collegamenti

Per gestire il traffico, esistono due tipi di connessioni sulle porte degli switch:

- **Access-Port:** Riguarda una sola VLAN e viene usato sui dispositivi finali (stampanti, computer...) che non sono a conoscenza dell'esistenza della VLAN;
- **Trunk-Port:** Collegamento punto-a-punto che trasporta il traffico di più VLAN. Si usa per collegare gli switch o il router tra di loro.



VTP (Virtual Trunking Protocol)

Il VTP è un protocollo proprietario di CISCO che consente di configurare le VLAN su un solo switch che inoltrerà tutte le informazioni agli altri switch della rete.

Viene quindi creato un gruppo di switch che si chiama VTP Domain, nel quale ogni modifica o creazione verrà inoltrata nel dominio in modo automatico.

Inter-VLAN

Per comunicare, due o più VLAN hanno bisogno di un dispositivo di livello 3, in genere in router o uno switch layer 3, in grado di leggere i parametri contenuti nell'header di rete.

Esistono 3 soluzioni:

1) Inter-VLAN Tradizionale

Per far comunicare le VLAN si usa un router, nel quale, ogni VLAN ha la rispettiva interfaccia su di esso. Ciascun interfaccia deve avere un indirizzo IP appartenente alla VLAN associata. Le porte dello switch associate al router sono di tipo Access.

Ha un grande problema: il numero di porte sul router è basso, quindi supporta davvero poche VLAN.

2) Router-On-A-Stick

Crea un unico collegamento tra switch e router con una porta Trunk. Invece di associare delle interfacce del router ad ogni VLAN, nel metodo Router-On-A-Stick si usano le Subinterfacce: delle interfacce virtuali o logiche associate ad un'interfaccia fisica del router.

Permette di risparmiare collegamenti e porte.

3) Switch-Based

In questa tecnica si usa un MultiLayer Switch (o Switch L2/L3), ovvero degli switch in grado di supportare anche funzionalità di livello 3 (come il forwarding per l'inoltro dei pacchetti nella rete). Quindi, invece di usare due dispositivi (switch e router), è possibile usare direttamente uno switch.

Private VLAN (PVLAN) *

Con le PVLAN si può segmentare ulteriormente le VLAN, ottenendo una VLAN primaria e delle VLAN secondarie. Sono molto utili in quanto scalabili e sicure (isolano a livello2). Vengono usate principalmente nei data center.

Primary VLAN

È la VLAN principale che trasporta il traffico verso le VLAN secondarie.

Secondary VLAN

Esistono due tipi di VLAN secondarie:

1) Isolated VLAN

I dispositivi all'interno di questa VLAN sono isolati da tutto il resto e possono comunicare solo con il router/gateway. Esiste una sola Isolated VLAN per ogni Primary VLAN. Sono molto utili per isolare server.

2) Community VLAN

I dispositivi all'interno di questa VLAN possono comunicare tra di loro e con il router/gateway ma non possono vedere dispositivi all'interno di altre community o Isolated VLAN.

Tipi di Porte

- **Promiscuous Port (Porte Promiscue):** È la porta collegata al router o gateway. Può comunicare con qualsiasi altra porta all'interno della stessa PVLAN.
- **Isolated Port:** È la porta collegata ai dispositivi nella Isolated VLAN. Può comunicare solo con la Promiscuous.
- **Community Port:** È la porta collegata ai dispositivi di una community VLAN. Può comunicare con la Promiscuous port e con le Community Port della sua stessa community.

VPN

VPN

Definizione

Una VPN (Virtual Private Network) è un servizio che crea una connessione crittografata (spesso definita “tunnel”) che mette in collegamento due dispositivi o due intere reti attraverso la rete pubblica.

È molto importante per la sicurezza e la privacy nelle comunicazioni Internet.

Per quanto riguarda la privacy, una VPN ti permette di nascondere il tuo indirizzo IP, navigando con quello del server a cui sei connesso.

Per quanto riguarda la sicurezza, tutto il traffico nella rete viene criptato usando il protocollo IPsec (IP secure), che agisce a livello Network.

Architettura di Rete

Ci sono 3 modelli di architetture di rete dell VPN principali:

- **Remote Access VPN** (client-to-site): un client si connette da remoto verso il gateway VPN, per esempio, dell'azienda. Si usano protocolli come TSL/SSL ma anche IPsec;
 - **Site-to-Site** (router-to-router): il tunnel viene stabilito direttamente tra due router o firewall (gateway). Si usa principalmente IPsec;
 - **Personal VPN**: non ci interessa per ora :)
-

IPsec (il goat delle VPN)

L'IPsec è un protocollo di livello 3 (network) che migliora il classico IP rendendolo più sicuro.

L'IPsec, in realtà, è un insieme di 3 protocolli: AH, ESP, IKE.

- **Authentication Header (AH)**: non cripta i dati, ma semplicemente garantisce l'autenticità dell'origine e l'integrità. Se i dati sono stati alterati durante il traffico, con il AH lo possiamo notare;
- **Encapsulating Security Payload (ESP)**: cripta il payload dei pacchetti inviati;
- **Internet Key Exchange (IKE)**: si occupa di autenticare, generare e scambiare le chiavi crittografiche per i tunnel.

In realtà, il livello di crittografia del pacchetto dipende dalla modalità di trasporto.

- **Modalità trasporto**: viene crittografato solo il payload dei pacchetti;
 - **Modalità Tunnel**: viene crittografato l'intero pacchetto e poi viene impacchettato in un header IP di un altro pacchetto.
-

Gateway VPN

Il gateway nel contesto delle VPN è il dispositivo in cui il tunnel “termina”.
È lui che si occupa di applicare l’IPsec e instradare i pacchetti attraverso il tunnel.
Può anche decidere chi può entrare e chi no nel tunnel.

Tipi di Tunneling

Una VPN può avere due tipi di tunneling:

- **Full tunneling**: tutto il traffico della rete va in VPN;
 - **Split tunneling**: solo il traffico destinato alla sede aziendale va in VPN. Il resto (youtube o google per esempio) va sulla connessione internet normale. Questo è ottimo per non sovraccaricare la banda della WAN. Usati principalmente nelle VPN remote access.
-

Instradamento nella Rete

I dati possono essere instradati in tre modi differenti:

1) **Trusted VPN**

Le trusted VPN consistono nell’usare le infrastrutture fisiche di un provider il quale garantirà la sicurezza dei dati attraverso distinzioni logiche della rete stessa. In breve, i dati della VPN viaggeranno negli stessi collegamenti degli altri dati del provider, ma verranno “etichettati” e isolati in modo che nessuno interferisca con loro.

2) **Secure VPN**

Sono le VPN più usate e comuni al giorno d’oggi (es NordVPN). Esse creano un tunnel crittografato e autenticato attraverso una rete pubblica (Internet) nel quale viaggiano i dati. Essa garantisce massima privacy e la sicurezza è tutta basata sulla robustezza degli algoritmi di cifratura usati.

3) **Hybrid VPN**

Una hybrid VPN unisce i vantaggi delle secure e trusted VPN. Sfrutta una linea dedicata per il traffico che necessita massima riservatezza (database gestionali) e una IPsec per il traffico normale della rete. Inoltre consente anche la ridondanza in quanto, se si dovesse guastare la linea fisica, entrerebbe in gioco l’altra VPN.

La soluzione più avanzata però è quella di usare le SD-WAN [[SD-WAN](#)].

SD-WAN

SD-WAN

Definizione

La SD-WAN (Software-Defined WAN) è un'architettura di rete che applica i principi della SDN (Software-Defined-Network) alle reti WAN.

L'obiettivo principale è quello di rendere più semplice la gestione della rete separando il piano di controllo dal piano di inoltro dei dati e centralizzando la configurazione tramite un controller software.

Al contrario di una WAN tradizionale dove tutti i router devono essere configurati manualmente, in una SD-WAN le policy e le configurazioni vengono distribuite in automatico dal controller centrale.

Come Funziona

Una SD-WAN è composta principalmente da due elementi:

1) Control Plane

È il responsabile della gestione della rete e prevede che un controller centrale:

- definisca le policy di routing;
- monitora lo stato della rete;
- distribuisca le configurazioni agli altri apparati della SD-WAN.

Tutto ciò rende la rete più scalabile e facile da amministrare.

2) Data Plane

Il data plane si occupa del trasporto dei dati.

Gli apparati SD-WAN creano tunnel sicuri, spesso basati su VPN IPsec, sopra qualsiasi mezzo di trasporto disponibile (fibra, reti mobili, internet...).

La rete fisica reale (fibra, interne...) si chiama underlay, mentre la rete virtuale che si trova sopra si chiama overlay.

La SD-WAN usa tecnologie avanzate come:

- **Multipathing**: utilizza più connessioni nello stesso tempo;
- **Dynamic Steering**: sceglie il collegamento migliore dove spostare il traffico di un canale con latenza o perdita di pacchetti (sceglie dove fare il failover);
- **DPI**: analizza il traffico per identificare le applicazioni e le priorità dei dati.

Failover

Un'altra funzione molto importante delle SD-WAN è il **failover**. Come detto in precedenza, il failover sposta automaticamente il traffico di una rete da un canale principale a uno secondario quando il primo non è più disponibile. Quindi ci sarà un router che controlla continuamente latenza, perdita di pacchetti e lo stato del link

Secure SD-WAN

Una Secure SD-WAN integra le funzioni di una normale SD-WAN con strumenti avanzati di sicurezza.

Oltre alla gestione intelligente del traffico, essa include:

- firewall di tipo NGFW;
- IDS/IPS;
- filtraggio web;
- VPN cifrate.

Una secure SD-WAN è la soluzione più sicura e moderna per collegare delle sedi di un'azienda.

Allocazione Risorse Server

Allocazione Risorse Server

I server della nostra azienda possono trovarsi direttamente nella struttura centrale oppure possiamo usare servizi di hosting o housing per avere server gestiti e conservati da terzi.

DMZ

Una DMZ (Demilitarized Zone/zona demilitarizzata), tecnicamente, è una sottorete logica o fisica che espone i servizi di un'organizzazione a una rete più ampia e non sicura (Internet). Possiamo quindi immaginare una DMZ come una sorta di zona “cuscinetto”, che serve a un'organizzazione a far usufruire dei propri servizi tramite internet in maniera controllata e sicura.

Dentro una DMZ solitamente ci si mettono i servizi che devono essere raggiungibili dall'esterno, come: server web, server mail, server FTP...

Architettura delle DMZ

Esistono due modi per strutturare una DMZ:

1) Firewall a Tre Gambe (Single Firewall)

Si usa un solo firewall dotato almeno di 3 interfacce di rete:

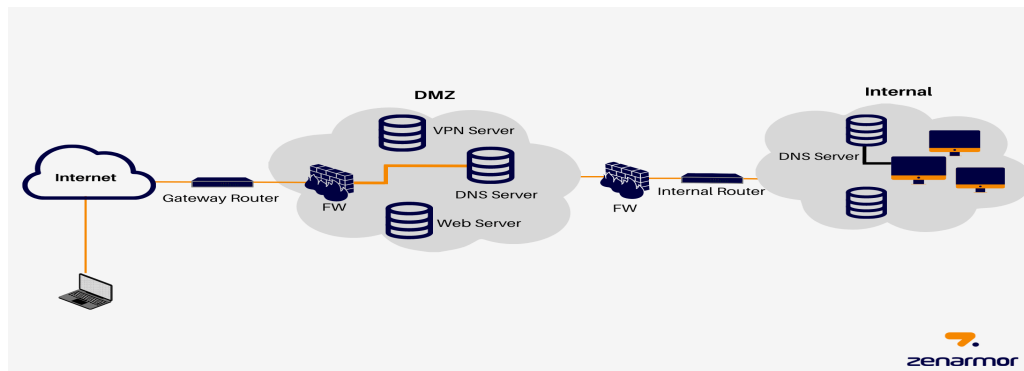
- **Interna:** l'intranet aziendale;
- **Esterna:** Internet;
- **DMZ**

Il firewall gestisce il traffico tra queste 3 interfacce secondo regole specifiche.

2) Firewall Back-To-Back (Dual Firewall)

È l'opzione più sicura e si usano due firewall in serie (FW->DMZ->FW). Avremo quindi un **firewall esterno** che permetterà di filtrare il traffico da Internet alla DMZ e un **firewall interno** che filtrerà il traffico dalla DMZ alla intranet.

Ciò fa sì che, se un hacker riuscisse a bucare il primo firewall, ne avrebbe ancora un altro da superare, spesso di marca o tecnologia diversa e più restrittivo.



Housing

L'Housing consiste nel comprare un server ma tenerlo in un datacenter di un provider. Ciò significa che il provider gestirà solo la struttura, quindi alimentazione e raffreddamento, mentre il proprietario del server dovrà gestire tutto il resto. Così facendo si ha pieno controllo sulla macchina ma a costi elevati.

Hosting

Nell'hosting si compra uno spazio virtuale in un server di un provider. Questo comporta a costi minori e un controllo nettamente minore sulla macchina. Il vantaggio è che sarà il provider a gestire l'intero server. L'hosting può essere:

- **Hosting Condiviso:** più utenti usano la stessa macchina e le risorse verranno condivise secondo un meccanismo "best effort". Ciò può comportare che alcuni utenti usino di più la macchina e saturino la CPU.
- **Hosting Dedicato:** si ha tutto il server per sé. È più costoso.

Cloud

Il cloud computing è una fornitura di servizi di calcolo (server, database...) tramite internet. Il cloud si basa quindi su un insieme di computer remoti connessi tra di loro (sistema distribuito 🤖). La virtualizzazione è la chiave di questo ecosistema, permettendo di creare più macchine virtuali all'interno di un'unica macchina fisica [\[Virtualizzazione\]](#).

Hypervisor

Il centro del cloud non sono i server fisici, ma gli hypervisor. Gli Hypervisor sono software (come VMware) che permettono di suddividere la macchina fisica in più macchine virtuali. Ciò permette:

- **Multi Tenancy:** più utenti possono usufruire della stessa macchina fisica senza che i dati si "incrocino";
- **Astrazione dello storage:** i dati non sono salvati su un solo disco rigido, ma vengono salvati su sistemi distribuiti su diversi nodi, garantendo la ridondanza.

Configurazione di una DMZ

Configurazione di una DMZ

Possiamo dividere la configurazione di una DMZ in 3 fasi:

- 1) Definizione delle zone
 - 2) Definizione delle ACL
 - 3) Configurazione del NAT
-

Definizione delle Zone

Per prima cosa dobbiamo definire fisicamente (per esempio nel *Single Firewall*) o logicamente (tramite *VLAN*) le tre zone.

Definizione delle ACL

In questa fase definiamo le regole per il traffico nella DMZ e vengono suddivise in base a dove vanno e da dove arrivano.

Inoltre dovremmo impostare l'azione (Action) che il firewall eseguirà con i pacchetti. Le azioni principali sono:

- **Allow:** permette il passaggio di un pacchetto;
- **Deny:** scarta il pacchetto e non manda nulla come risposta;
- **Reject:** scarta il pacchetto e manda un messaggio di errore.

1) Da Esterno a DMZ

L'obiettivo è quello di far vedere a tutti il sito web ma proteggere il server da tutto il resto.

Per far ciò impostiamo:

- Sorgente = Qualsiasi IP (0.0.0.0)
- Destinazione = IP del server nella DMZ
- Porte = Solo quelle concesse (es. 443)
- Azione = Allow (Permetti)

2) Da DMZ a Interno

La regola principale in questa "fase" è che la DMZ non deve MAI poter iniziare una sessione verso la LAN o, perlomeno, non in modo generico.

Il firewall ammette solo gli IP dei server nella DMZ tramite porte specifiche (es. 3306 se si vuole interrogare il database).

3) Da Interno a DMZ

Vogliamo che solo gli amministratori della rete possano interagire con la DMZ. Perciò avremo una configurazione di questi tipo:

- Sorgente = Rete Amministrativa
 - Destinazione = Tutta la rete DMZ
 - Azione = Allow (Permetti)
 - Porte = Quelle di gestione (es. 22 per l'SSH)
-

Configurazione del NAT

Dato che i server della DMZ hanno IP privati, dovremmo usare uno Static NAT che traduca gli IP privati dei server in IP pubblici e viceversa.

Bastion Host *

Il Bastion Host è un server super sicuro situato nella DMZ usato come unico punto d'accesso per la manutenzione e l'amministrazione dei server all'interno della rete privata.

Ci si accede dall'esterno tramite un protocollo sicuro (es. SSH). Successivamente, il Bastion Host richiede un'autenticazione forte, usando spesso Multi Factor Authentication. Una volta autenticato, l'utente può "saltare" verso i server nella rete interna.

Caratteristiche Principali di Sicurezza

- **Servizi Minimi:** Vengono rimossi tutti i software, protocolli e servizi non necessari;
- **IP statico e pubblico;**
- **Forte Logging:** qualsiasi azione effettuata su bastion host viene registrata.

È proprio quest'ultima caratteristica che ci fa preferire l'uso di un Bastion Host ad una semplice VPN per l'accesso remoto per la manutenzione. Inoltre, se il PC dell'utente dovesse essere infetto, la comunicazione avverrà sempre prima con il bastion host, evitando così di infettare la rete.

Virtualizzazione

Virtualizzazione

Definizione

La virtualizzazione è una tecnologia che permette di creare versioni “virtuali” di risorse hardware che fisicamente sono unite.

Hypervisor

Il centro di tutto è un software chiamato hypervisor. Questo software risiede sopra l'hardware fisico e distribuisce le risorse (CPU, RAM, Disco) alle varie macchine virtuali (VM).

Esistono due tipi di Hypervisor:

- **Tipo 1 (Bare Metal):** viene installato direttamente sull'hardware. È usato per massimizzare le prestazioni.
 - **Tipo 2 (Hosted):** viene installato come un normale programma su un sistema operativo già esistente.
-

Vantaggi

La virtualizzazione e le macchine virtuali hanno svariati vantaggi:

- **Efficienza e costi:** invece di usare 10 server fisici si usano N server virtuali su un unico server fisico;
- **Isolamento:** ogni macchina virtuale è isolata dal resto della macchina, quindi anche se una dovesse avere un malware, esso non si propagerà sul resto della macchina;
- **Snapshot e Portabilità:** è possibile “fotografare” lo stato di una VM in modo da salvarlo e tornare indietro in caso di guasto futuro.
- **Test e Sviluppo:** Si possono provare nuovi software su diversi sistemi operativi senza comprare nuovi computer.

RFID

RFID

Definizione

RFID (Radio Frequency Identification) è una tecnologia di identificazione automatica basata sulle onde elettromagnetiche.

Essa si compone di tre elementi:

- **Tag (Transponder)**: è composto da un microchip che memorizza i dati e da un'antenna. Possono essere passivi (alimentati dal reader) o attivi (energia autonoma);
- **Lettore (Reader)**: dispositivo che emette onde radio per scrivere o leggere i dati da o sul tag. Legge il segnale inviato dal tag e, grazie ad un'antenna, genera un campo elettromagnetico che attiva il tag;
- **Sistema di gestione**: un software che elabora i dati ricevuti.

La trasmissione tra reader e tag è di tipo wireless contactless.

Frequenze Utilizzate

La distanza e la velocità di lettura dipendono dalla frequenza radio utilizzata:

- **LF (Low Frequency)**: 125-134 kHz, raggio corto e attraversa bene i liquidi;
 - **HF (High Frequency)**: 13.56 MHz, raggio fino a 1 metro. È la base del NFC;
 - **UHF (Ultra High Frequency)**: 860-960 MHz, raggio lungo e lettura di massa (tanti tag al secondo).
-

Livelli ISO/OSI

L'RFID si concentra principalmente sui livelli Fisico e Data link:

1) Livello Fisico

Gestisce la comunicazione tra i dispositivi definendo come le onde radio devono essere modulate per trasportare il segnale.

2) Livello di Collegamento (Data Link)

Controlla l'accesso al mezzo dei dispositivi RFID per evitare collisioni.

Usa, per esempio, il protocollo ALOHA:

- I tag inviano i dati;
- Se si scontrano il lettore non capisce nulla e non invia la conferma di ricezione;
- Se i tag non ricevono la conferma aspettano un tempo casuale (es. uno 0,1s e l'altro 0,5s) e ci riprovano.

3) Livelli superiori

Alcuni tag si fermano al data link, mentre altri implementano più livelli:

- **Livello di Rete/Trasporto**, per far viaggiare i dati dei tag tra più lettori o nodi senza errori;
 - **Livello Applicazione**, che rappresenta il software che usiamo noi.
-

NFC

NFC (Near Field Communication) deriva da RFID ed è una tecnologia specializzata nello scambio di dati a brevissima distanza.

Infatti NFC, come detto prima, usa frequenze HF (13,56 MHz) e solitamente ha un raggio di azione fino a massimo 10cm.

NFC usa una connettività wireless bidirezionale: un dispositivo può comportarsi sia da lettore che da tag. Per far ciò, un dispositivo deve avere un chip NFC. Spesso è integrato nella SoC del telefono (chip centrale).

HTTP

HTTP

Definizione

HTTP (HyperText Transfer Protocol) è un protocollo di livello applicativo che si trova alla base del World Wide Web (WWW). Utilizza un'architettura client server e, infatti, il suo scopo è quello di far comunicare questi due. Esso si basa su un modello di comunicazione request/response. La porta su cui opera è la 80.

HTTP è un protocollo stateless, ovvero non mantiene le informazioni sullo stato del client tra una richiesta e l'altra.

Questa caratteristica rende la progettazione dei server più facile ma crea problemi quando è necessario mantenere tali informazioni del client. Per questo nascono i cookie e le sessioni.

Struttura dei Messaggi

I messaggi HTTP si dividono, quindi, in due tipi: Request e Response.

Una **richiesta HTTP** è composta da:

- Request Line (contenente metodo, uri e versione)
- Header
- Body (opzionale)

Una **risposta HTTP** contiene:

- Status Line (contenente versione, codice di stato, descrizione)
- Header
- Body con dati richiesti (opzionale)

Gli header HTTP sono fondamentali, e possono essere:

- **Content-Type**: indica il tipo di contenuto;
 - **Content-Length**: indica la lunghezza del messaggio;
 - **Cache-Control**: permette di gestire la cache;
 - **User-Agent**: permette di identificare un utente (es. browser e sistema operativo).
-

Metodi HTTP

I metodi HTTP definiscono il tipo di azione da eseguire sulla risorsa, e possono essere:

- **GET**: richiede una risorsa;
 - **POST**: invia dati al server (spesso usato per creare risorse);
 - **PUT**: aggiorna o sostituisce una risorsa;
 - **DELETE**: elimina una risorsa.
-

Codici di Stato HTTP

I codici di stato sono usati principalmente per il debugging e sono:

- **1xx** indicano che la richiesta è arrivata al server;
 - **2xx** indicano successo (201 indica la creazione di una risorsa);
 - **3xx** indicano redirezione (301 la pagina è stata spostata per sempre 302 temporaneamente);
 - **4xx** indicano errore nel client (404 la richiesta non esiste, 403 non hai i permessi, 401 non sei autenticato);
 - **5xx** indicano errore nel server (503 server in sovraccarico).
-

Sessioni, Cookie e Cache

I **cookie** sono dei piccoli file di testo memorizzati nella macchina del client che servono a ricordare chi sei, le tue preferenze o altre azioni a te collegate.

Permettono quindi l'autenticazione, il tracciamento e la personalizzazione dei contenuti.

Le **sessioni** servono a salvare i dati di un utente mentre naviga nel server. Il server crea un Session ID che manda al browser tramite cookie. Ogni volta che il browser cambierà pagina mostrerà al server il Session ID e lui si "ricorderà di te". Serve principalmente per gestire operazioni sensibili (es. bancarie) in cui l'utente non deve manipolare i dati.

La cache HTTP serve a evitare di scaricare le stesse cose più volte. Principalmente si trova sul lato client e rende la navigazione più veloce ed efficiente.

HTTPS

L'HTTPS è l'evoluzione sicura dell'HTTP. La sicurezza è garantita dall'uso di un secondo protocollo: il TLS (Transport Layer Security). La porta su cui opera è la 443.

L'HTTPS è un protocollo fondamentale e garantisce tre pilastri della sicurezza:

- **Criptazione**: tutto il traffico è criptato;
- **Autenticazione**: conferma l'identità dei siti evitando cloni;
- **Integrità dei Dati**: impedisce che i dati vengano alterati durante il trasferimento senza che il sistema se ne accorga.

Comunicazione con HTTPS

La comunicazione HTTPS avviene in varie fasi:

1) Richiesta

Il client manda una richiesta di connessione al server. Questa richiesta contiene:

- **Versione TLS** supportata;
- **Cipher Suite**: un elenco di algoritmi di cifratura conosciuti dal client;
- **Client Random**: una sequenza randomica di caratteri usata per diversificare le sessioni (se no sarebbe possibile replicarle).

2) Certificato

Il server riceve la richiesta e risponde con:

- Copia del suo **certificato TLS/SSL** che contiene la chiave pubblica (rilasciato da un CA);
- **Server Random**: stesso concetto del client random;
- Quale **Cipher Suite e versione TLS usare**.

3) Verifica

Il browser verifica le informazioni del certificato ottenuto e controlla se appartiene al dominio a cui si vuole accedere. Se non coincide manderà un avvertimento all'utente.

4) Scambio della Pre-Master Secret

Se il sito risulta veritiero, il client crea un'altra stringa di caratteri casuali chiamata Pre-Master Secret. Una volta creata, questa stringa viene criptata con la chiave pubblica del sito e inviata al server.

Solo il server riuscirà a decriptare il messaggio con la propria chiave privata.

5) Creazione della Chiave di Sessione

Ora che client e server sono in possesso di Client Random, Server Random e Pre-Master Secret, useranno queste informazioni per generare la stessa chiave di sessione.

La chiave di sessione è una chiave simmetrica.

6) Finished

Il client manda un messaggio di "Finished" criptato con la chiave di sessione al server e il server gli risponderà nello stesso modo. Ora tutta la comunicazione verrà criptata con la chiave di sessione.

FTP

FTP

Definizione

FTP (File Transport Protocol) è uno dei primi protocolli ideati (1971) ed è lo standard per il trasferimento dei file. Si basa principalmente sull'architettura client-server, dove il server contiene i file e il client, usando software specifici, li richiede. FTP lavora sulla porta 21. È utile perché permette lo scambio e la gestione da remoto di un "contenitore" di file.

Come Funziona

FTP stabilisce due connessioni/canali tra client e server:

- **Canale di Controllo**: usa la porta 21 e viene usato per scambiarsi le istruzioni e i comandi;
- **Canale dei Dati**: usa una porta variabile e viene usato solo per lo scambio effettivo dei file.

Alcuni dei comandi principali sono:

- **LIST**: restituisce la lista dei file;
 - **CWD**: cambia cartella;
 - **DELE**: elimina un file;
 - **RETR**: scarica un file;
 - **STOR**: carica un file;
 - **USER** e **PASS**: usati per l'autenticazione;
 - **QUIT**: termina la connessione.
-

Client FTP

Per usare FTP non basta un browser, ma abbiamo bisogno di un client FTP.

Un client FTP è un software che semplifica tutto il processo di connessione e gestione dei file di un server.

Tra i più famosi client FTP ci sono: FileZilla (gratuito), CyberDuck (usato anche per il cloud) e WinSCP (il migliore per windows).

FTPS

L'FTP di base non prevede nessun tipo di crittazione dei dati. Per questo è nato l'FTPS.

FTPS (File Transport Protocol Secure) è uguale all'HTTPS [\[HTTP\]](#): usa il protocollo TLS per la crittazione dei dati durante la connessione e per l'autenticazione del server tramite certificati digitali.

SFTP *

SFTP (SSH File Transport Protocol), nonostante abbia un nome simile, è molto diverso dal FTP e si basa sul protocollo SSH [[SSH](#)]. SFTP è il più sicuro tra i protocolli per il trasferimento dei dati perché fa passare tutto attraverso un tunnel criptato. Usa una sola porta, solitamente la 22, ed è "firewall-friendly", perché, al contrario del FTPS che usa tante porte, SFTP usa solo una porta. L'unico svantaggio è che richiede una potenza calcolo per la cifratura maggiore all'FTPS, ma con i computer moderni la differenza è impercettibile.

SSH

SSH

Definizione

SSH (Secure Shell) è l'evoluzione del vecchio protocollo Telnet. SSH permette l'accesso e il controllo di un dispositivo da remoto in modo sicuro. Esso opera sulla porta 22. Non si usa più Telnet perché non prevedeva cifratura.

Sicurezza e Autenticazione

Il protocollo SSH è uno dei più sicuri. Utilizza una cifratura a chiave asimmetrica per l'autenticazione e una chiave simmetrica per la cifratura dei dati.

Le chiavi asimmetriche vengono chiamate Chiavi SSH e sono:

- Chiave privata: salvata sul tuo computer;
- Chiave pubblica: salvata sul server.

Inoltre usa un sistema di HMAC (Hash-based Message Authentication Code) per l'integrità e l'autenticazione. HMAC combina una funzione di hash con una chiave segreta.

Funzioni Principali

Le funzioni principali del SSH sono:

- **Accesso Remoto (Shell):** Accedi e controlli un computer da remoto;
 - **Tunneling (Port-Forwarding):** Crea un tunnel sicuro per far passare altri tipi di traffico. Ci sono due tipi di tunneling: Local Port Forwarding, consente di accedere ad un servizio su un server che non è esposto a Internet, e Remote Port Forwarding, permette ad un server di accedere a un servizio che gira su un computer.;
 - **Trasferimento File:** SFTP [\[FTP\]](#).
-

Architettura SSH

SSH è suddiviso in tre strati:

1) Transport Layer (TCP/IP)

Si occupa della cifratura iniziale e dell'integrità dei dati.

2) Authentication Layer

Controlla se sei chi dici di essere tramite password, chiavi o sistemi a due fattori.

3) Connection Layer

Questo strato si occupa di gestire più "canali" contemporaneamente.

Handshake

La fase di connessione con il server si divide in 3 fasi:

1) Verifica del Server

Una volta digitato il comando "ssh utente@server", il server invia la sua chiave pubblica. Il nostro computer controllerà se la conosce già. Se è cambiata riceveremo un messaggio di avvertimento.

2) Accordo sulla Cifratura

I due dispositivi si accordano sul tipo di algoritmo da usare per quella sessione.

3) Autenticazione dell'Utente

Una volta stabilito un tunnel sicuro, l'utente invierà i suoi dati (password o firma della chiave privata) al server per essere autenticato.

Appunti per la Prova Scritta

Appunti per la Prova Scritta

La soluzione più comoda quando si usano le VLAN è quella di effettuare Switch-based inter-vlan: usiamo uno switch layer 3 che permette di far comunicare le VLAN.

I protocolli e gli standard utili sono:

- IEEE 802.3 (Ethernet): quando si parla di LAN (o comunque c'è una LAN, quindi sempre);
- IEEE 802.11 (Wi-Fi): quando c'è una parte wireless della rete;
- IEEE 802.1w: permette il Management Frame Protection [[Attacchi alle Reti Wireless](#)];
- IEEE 802.1Q: permette l'uso delle VLAN [[VLAN](#)];
- IEEE 802.1X: si usa quando usiamo un server RADIUS [[Sicurezza nelle WLAN](#)];
- IPsec: usato per creare i tunnel nelle VPN (a sua volta diviso in 3 protocolli [[VPN](#)]);
- RTSP (Real Time Sharing Protocol): usato per la condivisione in tempo reale di video. Utile se si vogliono inserire telecamere;
- HTTPS: se si usa un server web, esso comunicherà attraverso questo protocollo;

Per i server potrebbe essere una chicca in più aggiungerli ad una PVLAN Isolated, per garantire ancora più sicurezza [[VLAN](#)].

Per garantire sicurezza sul server web si può usare un Web Application Firewall (WAF) che serve a proteggere il server web da attacchi di tipo SQL Injection o Cross-Site Scripting. Va installato prima del server web.

Per il firewall della sede centrale è ottimo usare un NGFW con tutte le sue funzioni di DPI, IPS e sandboxing. Inoltre è buono citare che lavora sul full stack OSI (layer 3,4,5,6,7).